

RESEARCH ARTICLE

EARN ASHRM CE FOR THIS ARTICLE



Managing legal risks in health information exchanges: A comprehensive approach to privacy, consent, and liability

Tariq K. Alhasan LLB, LLM

Faculty of Law, Al-Ahliyya Amman University,
Amman, Jordan

Correspondence

Tariq K. Alhasan, Faculty of Law, Al-Ahliyya
Amman University, Amman, Jordan.
Email: t.alhasan@ammanu.edu.jo

EARN ASHRM CE FOR THIS ARTICLE

This article is ASHRM CE eligible. Earn 1.0
credit hours of Continuing Education by passing
an online quiz based on your reading at
ASHRM.org/JournalCE.

Abstract

Health Information Exchanges (HIEs) are revolutionizing healthcare by facilitating secure and timely patient data sharing across diverse organizations. However, their rapid expansion has introduced significant legal and ethical challenges, particularly regarding privacy, informed consent, and liability risks. This paper critically assesses the effectiveness of existing legal frameworks, including Health Insurance Portability and Accountability Act (HIPAA) and General Data Protection Regulation (GDPR), in addressing these challenges, revealing gaps in their application within HIEs. It argues that current consent models fail to provide meaningful control for patients, while privacy protections are weakened by issues such as re-identification and jurisdictional inconsistencies. Moreover, liability in data breaches remains complex due to ambiguous responsibility among stakeholders. The study concludes that reforms are needed, including dynamic consent models, standardized liability frameworks, and enhanced data governance structures, to ensure secure, ethical, and effective data sharing. These changes are essential to fostering patient trust, improving healthcare delivery, and aligning with Sustainable Development Goal (SDG) 3—ensuring healthy lives and promoting well-being for all.

INTRODUCTION

Health Information Exchanges (HIEs) represent a transformative development in healthcare, facilitating the secure electronic sharing of patient information among healthcare providers and organizations. By providing timely access to patient histories, HIEs offer a solution to the long-standing issue of fragmented healthcare data, enabling coordinated care and comprehensive decision-making.¹ This coordinated data exchange has grown increasingly important, especially in response to challenges highlighted by the COVID-19 pandemic, which underscored the necessity of rapid and reliable information flow to support public health and individual care needs.² The adoption of HIEs aligns with the broader shift toward value-based care and population health management, where data-driven insights are critical to improving healthcare quality and reducing costs.

HIEs connect diverse Information and Communication Technology (ICT) systems across various organizations, including hospitals, clinics, and public health institutions.¹ These systems rely on robust interoperability frameworks and data exchange standards to ensure that patient data is available when needed while maintaining privacy and security.³ In addition to

improving healthcare efficiency, HIEs support key public health goals, such as reducing emergency department readmissions and length of stay, and they increasingly integrate social determinants of health (SDOH) data to provide a more comprehensive understanding of patient needs.⁴

While HIEs promise significant advancements in healthcare delivery, they also introduce complex legal and ethical challenges. These challenges stem from the sensitive nature of healthcare data and the risks associated with data sharing across multiple entities with varied responsibilities. Privacy concerns remain central, as patients' willingness to share personal information often depends on perceived data security and trust in the entities handling their information.⁵ Furthermore, the legal landscape surrounding patient consent for data sharing is fragmented, with varying requirements across state and federal jurisdictions, making compliance challenging for HIEs.⁶

The need for robust risk management practices within HIEs has never been greater, as risks such as data breaches, compliance issues, and potential liabilities require urgent attention. This study is crucial for identifying gaps in existing legal frameworks and proposing solutions to enhance privacy protections, consent clarity, and accountability within HIEs. By addressing

these areas, healthcare providers can make informed decisions about HIE participation, balancing the benefits of data access with the need to safeguard patient trust and data security. In alignment with Sustainable Development Goal (SDG) 3, which is part of the United Nations Agenda 2030 and emphasizes ensuring healthy lives and promoting well-being for all at all ages, enhancing the integrity and security of HIEs is essential in fostering trust and improving healthcare delivery across diverse populations.^{7, 8}

This paper addresses the research question: **“How adequate are current legal frameworks in mitigating privacy, consent, and liability risks associated with Health Information Exchanges, and what reforms are necessary to support safe, ethical, and effective data sharing in healthcare?”**

This question reflects a pressing need for clarity in the legal obligations and protections for entities involved in HIEs, as well as the importance of establishing standards that support both patient rights and healthcare innovation. The answer to this question will help shape the future of HIEs, guiding legal reforms that are adaptable to technological advances and shifting healthcare priorities.

LITERATURE REVIEW

Current privacy and data protection laws

Privacy and data protection laws significantly influence the operation and acceptance of HIEs, shaping trust and compliance. Key frameworks include the Health Insurance Portability and Accountability Act (HIPAA) in the United States and the General Data Protection Regulation (GDPR) in the European Union, each with distinct approaches and implications for risk management.

HIPAA: Simplified data sharing with security challenges

HIPAA permits sharing of Protected Health Information (PHI) for treatment, payment, and healthcare operations without explicit patient consent, enabling smoother HIE participation.⁹ However, HIPAA enforces stringent data security requirements, posing compliance challenges when HIEs operate across states with varying privacy standards. Risk professionals must ensure robust security protocols and inter-state compliance to prevent breaches.

GDPR: Emphasis on patient autonomy

GDPR focuses on individual control over personal data, requiring explicit consent for processing sensitive information.¹⁰ Its extraterritorial reach means HIEs handling data from EU citizens must meet GDPR's rigorous standards or face significant fines. This rights-based approach complicates cross-border data

sharing, requiring risk managers to adopt strategies like harmonized consent models and cross-jurisdictional compliance frameworks.¹¹

Implications for risk management

The contrasting foundations of HIPAA and GDPR highlight the need for harmonized privacy laws or interoperable frameworks to support cross-border HIEs. Risk professionals must:

- Implement adaptive consent models to balance operational needs with compliance.
- Establish clear protocols for managing jurisdiction-specific requirements.
- Advocate for standardized data protection measures to reduce complexity and enhance trust.

By addressing these challenges, risk managers can ensure compliant, secure, and effective data-sharing practices within HIEs.

Informed consent and patient autonomy

Traditional informed consent models in healthcare are increasingly challenged by digital health environments, particularly within HIEs. Historically, consent was obtained through static, one-time agreements that allowed patients to grant or withhold permission for specific procedures or data uses. However, HIEs require broader, ongoing access to patient information, often leading to blanket consent forms that may not adequately inform patients about how their data is shared or reused in real-time.¹²

Studies have shown that blanket or static consent models fail to uphold patient autonomy in HIE settings, as patients may not fully understand the implications of consenting to comprehensive data sharing agreements.¹³ The concept of “dynamic consent” has emerged as a potential solution, offering patients more granular control over their data, allowing them to adjust their consent preferences over time, and providing opportunities to opt out of specific data uses. While dynamic consent could enhance autonomy and transparency, implementing this model in HIEs raises logistical and technical challenges, such as increased administrative costs and complex IT infrastructure needs.¹⁴

Ensuring meaningful patient consent in HIEs is not only an ethical imperative but also central to maintaining trust and compliance with privacy laws, especially in jurisdictions like the EU where GDPR mandates specific consent requirements for sensitive data. Achieving informed consent in HIEs will require innovative approaches that balance patient control with the operational needs of healthcare providers, which could involve leveraging technology to streamline consent management and communication.¹⁵

Liability in data breaches

Liability in data breaches is a critical concern for HIEs, given the multi-entity structure of these exchanges, which complicates accountability in the event of a security incident. When multiple healthcare providers, third-party vendors, and IT systems interact in an HIE, identifying responsibility for a data breach can be complex. Recent legal cases highlight that breaches in one organization can expose data across the entire HIE network, raising questions about shared liability and the distribution of financial and legal repercussions.¹⁶

The risks associated with shared liability are compounded by legal discovery obligations. Patient data shared within HIEs may be subject to subpoenas or legal discovery, especially in cases of medical errors or malpractice. Although federal protections such as the Patient Safety and Quality Improvement Act offer some legal shields for patient safety data, these protections do not always extend to other forms of medical information exchanged within HIEs.¹⁷

One proposed approach to managing liability in HIEs is the establishment of standardized contractual agreements that clearly delineate responsibilities and liabilities among all participating entities. These agreements could specify security standards, breach notification protocols, and financial liabilities for breaches. However, implementing such agreements across diverse entities with varying compliance capabilities remains a significant barrier. Strengthening liability frameworks could provide clearer legal pathways for handling data breaches, which would support both risk management and trust-building within HIE networks.¹⁸

Emerging governance models

Recent advancements in data governance offer promising frameworks for addressing the legal and ethical challenges of HIEs. Traditional governance structures in healthcare focus on centralized control, where individual organizations manage patient data in isolation. Emerging models, such as data trusts and federated data governance, present alternatives that prioritize transparency, accountability, and patient control in data sharing.

A data trust model, for instance, designates a neutral, third-party trustee to oversee data sharing within an HIE, with a mandate to ensure patient rights and data security. Data trusts have been successfully implemented in sectors like finance and environmental data sharing and show potential for healthcare, where they could help balance the interests of patients, providers, and policymakers in HIEs.¹⁹

Federated data governance models also hold promise for HIEs, especially in settings where data cannot be easily centralized. This approach allows organizations to maintain control over their data while enabling secure, query-based data sharing through encrypted channels. Such models align with privacy-centric regulations like GDPR, as they enable data usage without physically transferring sensitive information across borders.²⁰

The adoption of these governance models, however, is not without obstacles. Data trusts require robust legal frameworks to define trustee responsibilities, while federated governance demands sophisticated technical infrastructure. Addressing these challenges will be essential for leveraging these models to improve privacy, consent, and liability protections in HIEs, ultimately supporting a more sustainable and ethical approach to healthcare data sharing.

PRIVACY RISKS IN HIEs

Gaps in current privacy protections

HIEs play a critical role in advancing coordinated healthcare by enabling secure, efficient data sharing among healthcare providers. However, existing privacy regulations, notably the HIPAA in the United States, often fall short in addressing the unique privacy risks associated with HIEs. HIPAA's Privacy Rule establishes standards for the protection of health information, permitting data sharing for purposes of treatment, payment, and healthcare operations without explicit patient consent.²⁰ While this facilitates data flow within healthcare settings, HIPAA's provisions were primarily designed for traditional, centralized healthcare models and may not fully account for the complexities of decentralized HIE networks.

One significant limitation in current privacy protections is the risk of re-identification of de-identified data within HIEs. Although HIPAA provides guidelines for de-identifying health data to minimize privacy risks, advances in data analytics have made it increasingly possible to re-identify individuals from seemingly anonymous data sets. Studies show that combining de-identified health data with external data sources, such as demographic information, can reveal the identities of individuals, exposing sensitive information that was intended to be protected.²¹ This risk is heightened within HIEs, where multiple healthcare entities contribute data, potentially increasing the volume and diversity of data available for re-identification.

Additionally, HIPAA's Privacy Rule lacks specific provisions for secondary data use within HIEs. While primary uses of data, such as direct patient care, are covered, secondary uses—such as for research or quality improvement—often fall into a gray area. This regulatory gap may lead to unauthorized or unintentional data access, further compromising patient privacy. To address these issues, stronger regulatory mechanisms or contractual safeguards that explicitly limit data re-identification and clarify permitted uses of de-identified data within HIEs are necessary to bolster privacy protections.

Jurisdictional challenges in data privacy

The decentralized and cross-jurisdictional nature of many HIEs presents unique challenges in data privacy compliance. As HIEs often operate across state lines or even internationally, they must navigate a patchwork of privacy regulations that vary widely by

jurisdiction. In the U.S., each state may have its own privacy laws, some of which impose stricter data protection standards than HIPAA. For instance, California's Consumer Privacy Act (CCPA) grants patients the right to request data deletion, a provision that can complicate data management within HIEs operating across multiple states.²² Managing these differing state requirements imposes a substantial administrative burden on HIEs, often leading to inconsistencies in privacy practices that can undermine compliance efforts.

International data sharing further complicates privacy management in HIEs, particularly when dealing with jurisdictions governed by the GDPR in the European Union. GDPR's stringent consent requirements, individual rights provisions, and data transfer restrictions create compliance challenges for U.S.-based HIEs that interact with EU citizens' data. For example, GDPR mandates explicit consent for data processing and requires data controllers to establish legal bases for cross-border data transfers.²³ These requirements are often difficult to reconcile with HIPAA's more flexible approach to consent, leaving HIEs at risk of violating either U.S. or EU regulations when handling cross-border data exchanges.

To address these jurisdictional challenges, there is a growing need for interoperable data protection standards or bilateral agreements that harmonize privacy requirements across regions. Initiatives like the U.S.-EU Privacy Shield, though recently invalidated, underscore the importance of creating frameworks that support legal, secure cross-border data sharing without compromising patient privacy. Without such frameworks, HIEs operating across jurisdictions will continue to face compliance difficulties, increasing the risk of privacy violations and legal penalties.

Implications for patient trust

Privacy risks within HIEs, such as re-identification and jurisdictional inconsistencies, have direct implications for patient trust, which is foundational to the success of data-sharing initiatives. When patients perceive that their personal health information may be compromised, they are less likely to consent to data sharing, which can limit the effectiveness of HIEs in improving healthcare outcomes. Studies indicate that patients who lack trust in the privacy and security of HIEs may choose to withhold critical information from healthcare providers, leading to incomplete medical records and suboptimal care.²⁴

Furthermore, privacy concerns in HIEs can lead to reputational damage for healthcare providers involved in data-sharing networks. High-profile data breaches or instances of unauthorized data use within HIEs can result in public distrust, not only toward specific providers but also toward the broader concept of electronic health information exchange. In such cases, patient confidence in the healthcare system is eroded, potentially decreasing overall participation in HIEs. This reluctance to share data can undermine the primary objective of HIEs—improving care coordination and patient outcomes—by creating gaps in medical records and limiting the availability of comprehensive patient information.

For healthcare risk management, addressing privacy risks in HIEs is essential to maintaining patient trust and ensuring compliance. Strategies such as transparent privacy policies, regular privacy audits, and enhanced patient control over data access can help mitigate privacy concerns. Additionally, educating patients about the benefits of HIEs and the measures in place to protect their data can foster trust, encouraging more individuals to participate fully in data-sharing initiatives. Maintaining patient trust through robust privacy protections not only supports compliance but also enhances the long-term viability and impact of HIEs on healthcare delivery.

CHALLENGES IN INFORMED CONSENT WITHIN HIEs

Limitations of traditional consent models

In the context of HIEs, traditional consent models face significant limitations due to their static, one-time nature, which inadequately addresses the dynamic and evolving nature of digital health data use. Typically, HIEs rely on a broad or blanket consent approach, where patients provide consent for data sharing at the initial point of interaction. While this method may streamline the process, it does not allow for ongoing patient involvement or updates regarding new data uses, leading to a lack of transparency and potentially undermining informed consent.

One major issue with traditional consent models in HIEs is the lack of clarity around secondary data use. Secondary uses include research, quality improvement initiatives, and other applications beyond direct patient care. In most HIEs, patients are not given detailed information on how their data may be used in the future, nor are they provided with an option to opt in or out of specific secondary uses. This lack of specificity can erode trust, as patients may feel they are not fully informed about the scope of data sharing agreements.²⁵ Furthermore, studies show that static consent practices contribute to "consent fatigue," where patients feel overwhelmed by broad, complex agreements and, consequently, are less likely to engage with or understand the terms they are agreeing to.²⁶

Moreover, static consent models may conflict with regulatory standards, such as the GDPR's emphasis on specific, informed, and revocable consent. Blanket consent, in particular, fails to meet these criteria as it does not allow patients to update or withdraw consent in response to evolving data practices, which can lead to compliance challenges and legal risks for HIEs.²⁷

Innovative consent models

To address the limitations of traditional consent practices, innovative consent models have emerged that aim to improve patient autonomy, transparency, and engagement. These models, including dynamic consent, digital consent tools, and tiered consent, provide more flexible and interactive approaches to consent management.

1. **Dynamic consent:** Dynamic consent offers a personalized, adaptive approach to managing patient data consent over time. Unlike static models, dynamic consent enables patients to update their preferences as new data-sharing opportunities arise. This model is particularly advantageous in HIEs, where data use and sharing evolve continuously. By facilitating an ongoing dialogue with patients, dynamic consent can improve engagement and trust, as patients retain control over their data at every stage.²⁸ However, implementing dynamic consent presents challenges, including the need for advanced IT infrastructure to manage real-time consent updates and the risk of “consent fatigue,” where patients may become overwhelmed by frequent requests to update preferences.²⁹
2. **Blockchain-based consent systems:** Blockchain technology offers a secure and transparent solution for managing consent within HIEs. By recording consent transactions on an immutable ledger, blockchain can provide a verifiable history of consent decisions, ensuring that patients’ preferences are respected and making unauthorized data access more difficult. Additionally, blockchain-based systems can employ smart contracts to automate consent management, allowing patients to set conditions under which their data can be accessed or used.^{30, 31} Despite these benefits, blockchain-based models must overcome regulatory and interoperability challenges to become viable options within healthcare data systems.
3. **Tiered consent:** Tiered consent enables patients to specify different levels of consent for various types of data use, providing a balance between granular control and ease of implementation. In an HIE setting, patients could use tiered consent to authorize specific types of data sharing (e.g., for direct care vs. research purposes), enhancing transparency without overwhelming patients with excessive detail.³² Tiered consent models can be particularly effective in addressing patients’ varying comfort levels with data sharing, but they require clear communication and education to ensure patients understand the implications of each tier.

These innovative models represent significant advancements in informed consent, supporting patient-centered data governance in HIEs. Nevertheless, implementing these models in HIEs requires technological infrastructure, regulatory alignment, and careful design to prevent consent fatigue and maintain patient engagement.

Balancing efficiency with comprehensive consent

Ensuring that consent processes are both efficient and comprehensive poses a complex challenge in HIEs. While comprehensive consent models provide greater transparency and patient control, they can be time-intensive, impacting the operational efficiency of HIEs. Balancing these aspects requires leveraging digital tools that streamline consent processes without compromising patient protection or autonomy.

1. **Digital consent interfaces:** Digital interfaces, such as mobile health apps or online portals, enable patients to manage their

consent preferences easily and conveniently. By integrating consent options within digital health platforms, HIEs can facilitate real-time updates to consent, reducing the need for in-person interactions and enhancing accessibility for patients.³³ Studies on digital consent interfaces in healthcare demonstrate improved user satisfaction and a higher likelihood of patients thoroughly reviewing consent terms compared to traditional paper-based methods.¹ These interfaces can also provide educational resources, ensuring that patients have a better understanding of their options, which supports informed decision-making.

2. **Automated consent solutions:** Automated solutions, such as smart contracts or machine learning algorithms, can further enhance efficiency by automatically managing consent based on pre-specified patient preferences. For example, blockchain-based smart contracts can execute patient-approved data-sharing agreements without the need for manual oversight, ensuring that only authorized entities access the data.^{34, 35} Automated solutions also enable HIEs to comply with regulatory requirements by providing a secure audit trail of consent transactions. However, implementing these solutions requires significant technical resources and expertise, which may be a barrier for smaller HIEs with limited budgets.
3. **Simplified consent forms with supplementary information:** To balance comprehensiveness and efficiency, HIEs can implement simplified consent forms that provide core information upfront, supplemented by additional resources accessible through digital links or QR codes. This approach allows patients to quickly grasp the main aspects of consent while having the option to delve into more detailed information as needed. Simplified forms, combined with digital supplements, support patient autonomy without creating excessive delays or administrative burdens in data-sharing processes.³⁶

In conclusion, the integration of digital tools and innovative consent models offers promising pathways for HIEs to manage consent in a way that respects patient rights while maintaining operational efficiency. By employing adaptable consent frameworks and streamlining processes through technology, HIEs can better navigate the complexities of informed consent, ensuring that patients remain informed and engaged without unnecessary friction in data sharing. Balancing these factors will be essential for the future success and ethical viability of HIEs, as they seek to improve healthcare delivery through responsible and transparent data practices.

LIABILITY AND ACCOUNTABILITY IN DATA SHARING

Complexity of assigning liability in HIEs

In HIEs, determining liability in the event of a data breach is complex due to the involvement of multiple stakeholders, including healthcare providers, HIE operators, third-party

vendors, and even patients. The collaborative nature of HIEs introduces legal ambiguities regarding responsibility, especially in cases where breaches involve third-party systems or multiple entities. This challenge is compounded by the lack of uniform legal standards for assigning blame when healthcare providers and vendors share data management and security responsibilities.

Under frameworks like the HIPAA, healthcare providers are required to protect patient data, but third-party vendors and HIE operators also play crucial roles in ensuring security. When a breach occurs, it may be challenging to pinpoint whether it was due to insufficient security measures by the healthcare provider, a vulnerability in the vendor's software, or an operational failure by the HIE operator. Contractual indemnification clauses, which often absolve vendors of certain liabilities, further complicate liability assignment and can limit recourse for affected patients and healthcare organizations.³⁷

Legal ambiguities also arise from evolving healthcare technologies, including the use of Artificial Intelligence (AI) and Internet of Medical Things (IoMT) devices within HIEs, which create new points of vulnerability and increase the potential for shared responsibility in breaches. Current legal frameworks often struggle to address these complexities, as traditional principles of tort law may not easily apply to situations where data is dynamically shared and managed across interconnected systems.³⁸

Case studies and precedents

Several high-profile cases illustrate the complexities of assigning liability within HIEs. These cases emphasize the need for clearer accountability frameworks to enhance data security and trust.

1. Shared responsibility between entities

- **Example:** In the **Thompson Coburn and Presbyterian Healthcare Services Breach (2024)**, a cyberattack exposed sensitive patient data managed by a third-party law firm. Legal challenges highlighted gaps in defining liability between healthcare providers and external vendors.³⁹
- **Lesson:** Risk professionals must enforce detailed contractual agreements that specify cybersecurity responsibilities and liabilities among all parties involved.

2. Dual accountability in security lapses

- **Example:** The **SingHealth Data Breach (2018)** exposed data of 1.5 million patients due to lapses in cybersecurity by both SingHealth and its IT provider. Both entities were fined, showcasing the difficulty in delineating liability in shared data systems.⁴⁰
- **Lesson:** Risk managers should implement regular audits and joint risk assessments to ensure all parties meet security standards.

3. Accountability in multi-entity environments

- **Example:** The **Change Healthcare Cyberattack (2024)** led to lawsuits questioning the liability of the parent company and third-party vendors. This case highlighted

the challenges of managing accountability in complex, multi-entity HIEs.⁴¹

- **Lesson:** Establish clear incident response protocols and ensure all stakeholders are equipped to handle breach scenarios collaboratively.

Key takeaways for risk professionals:

- **Define roles clearly:** Ensure contracts explicitly allocate security responsibilities and liabilities among all entities.
- **Proactive risk assessments:** Conduct joint evaluations of vulnerabilities across the HIE network.
- **Preparedness for incidents:** Develop standardized breach response protocols to minimize delays and confusion during incidents.

By addressing these lessons, risk managers can reduce disputes, improve accountability, and strengthen the overall trust in HIE systems.

Need for standardized liability guidelines

The outlined cases highlight the urgent need for standardized liability guidelines in HIEs. Clear, uniform frameworks can enhance accountability, streamline risk management, and improve transparency among entities handling sensitive health data. These frameworks should include:

1. **Defined roles and responsibilities:** Standardized guidelines should clearly define the responsibilities of each entity in an HIE, including healthcare providers, operators, and vendors, to prevent overlaps or gaps, particularly in data security and breach response, and ensure all parties understand their obligations and consequences of noncompliance.⁴²
2. **Contractual obligations:** Contracts between healthcare providers and vendors should include clear data security requirements and liability clauses for breaches.⁴³ Standardized templates can establish baseline expectations, prevent disputes over indemnification, and align with regulations like HIPAA and GDPR to ensure consistent sharing of responsibilities across HIEs.⁴⁴
3. **Incident response protocols:** Standardized protocols for breach notification, investigation, and remediation would ensure swift,⁴⁵ coordinated responses by establishing timelines and reporting requirements, enabling all HIE entities to act efficiently and transparently during security incidents.⁴⁶
4. **Risk assessment and compliance audits:** Regular risk assessments and independent compliance audits should be mandated to identify vulnerabilities, ensure adherence to security standards, and proactively manage risks, reducing the likelihood of breaches.⁴⁷

Implementing standardized liability guidelines would not only provide clarity in assigning responsibility but also foster a culture of proactive risk management among HIE participants. By setting clear expectations, healthcare providers, vendors, and

HIE operators could work collaboratively to secure patient data, ultimately enhancing trust and operational stability within HIEs.

In conclusion, while the collaborative nature of HIEs offers substantial benefits for patient care, it also introduces significant complexities in liability and accountability. Standardized guidelines are essential for managing these complexities effectively, providing a foundation for clear, enforceable standards that protect patient privacy, uphold compliance, and ensure that entities within HIEs can work together in a transparent, accountable manner.

ADDRESSING SECONDARY DATA USE AND ETHICAL CONCERNS

Secondary use risks

The secondary use of patient data in HIEs introduces notable legal and ethical risks, particularly as such data is often utilized beyond its original intent. Unlike primary data use, where patient information is collected and shared with clear consent for direct healthcare purposes, secondary use often involves research, public health, or commercial applications that lack explicit patient authorization. The risks of secondary data use include the potential for privacy violations, unauthorized access, and even the possibility of re-identification despite anonymization measures.⁴⁸

One of the main ethical concerns is the infringement of patient autonomy, as secondary data uses frequently proceed without patients' direct knowledge or consent, diminishing their control over their personal health information. Moreover, the aggregation of vast amounts of health data from multiple sources in HIEs increases the risk of data breaches. The broader accessibility of this information raises questions about how well HIEs can maintain security and prevent unauthorized parties from exploiting or misusing sensitive data.⁴⁹ These risks underscore the importance of establishing ethical guidelines and secure data handling practices for secondary data use within HIEs.

Public health benefits versus patient privacy

The secondary use of HIE data holds immense promise for public health, particularly in epidemiological research, health policy planning, and understanding disease trends. During public health crises, such as the COVID-19 pandemic, the rapid sharing of health data through HIEs allowed for more efficient responses, better resource allocation, and improved understanding of the virus's spread and impact. Secondary data use in such contexts can provide valuable insights, drive innovations in treatment and prevention, and ultimately improve healthcare outcomes on a societal level.⁵⁰

However, while these benefits are compelling, they must be balanced against the individual's right to privacy and control over personal information. Patients often have varying expectations about how their data will be used, with a common

assumption that sensitive health information will not be accessed for purposes beyond direct care without their explicit consent. Public attitudes reflect a general willingness to support data sharing for public health but also show a preference for transparency and control over how and why their data is used. The ethical challenge lies in upholding the collective benefits of data use while safeguarding individual rights and maintaining public trust.⁵¹

Proposed safeguards for secondary use

To navigate the complexities of secondary data use within HIEs, a series of procedural safeguards are recommended to protect patient privacy and ensure ethical standards:

1. **Explicit consent requirements:** For non-primary data uses, implementing a model that requires explicit patient consent can enhance transparency and respect for patient autonomy.⁵² Such a model may include tiered or dynamic consent options, allowing patients to specify the types of secondary uses they permit for their data.⁵³ This approach ensures that patients are informed and empowered in the decision-making process, fostering trust and minimizing the risk of unauthorized data usage.
2. **Clear usage limitations:** Establishing clear limitations on how data can be used in secondary contexts is essential. Usage limitations could involve defining specific, allowable purposes for secondary data use, such as research aimed at improving population health. Data governance frameworks should enforce these limitations through contracts and data-sharing agreements with third parties, ensuring that secondary uses align with the initial purpose and patient expectations.⁴⁸ By maintaining these boundaries, HIEs can mitigate the risk of data misuse and prevent the exploitation of sensitive health information.
3. **Robust data anonymization and de-identification:** While anonymization is a common approach to privacy protection, the potential for re-identification remains, especially with advances in data analytics and cross-referencing capabilities. To counter this, HIEs should adopt sophisticated anonymization techniques, such as differential privacy or multi-party computation, which reduce re-identification risks while still allowing data to be used for legitimate research purposes. Regular audits of anonymization practices can ensure that privacy standards are consistently met.⁵⁴
4. **Transparency and public engagement:** Transparency about secondary data uses is crucial for maintaining patient trust. HIEs should communicate openly with the public about how patient data is utilized, both in primary and secondary contexts. Engaging patients and the broader community in discussions about data usage policies can improve understanding and acceptance, as patients feel reassured that their privacy concerns are taken seriously.⁵⁵ Public reporting on data-sharing practices and outcomes from secondary data use can further enhance accountability and reinforce ethical standards.⁵⁶

5. **Ethics committees and oversight mechanisms:** The establishment of independent ethics committees to review proposed secondary data uses can provide an additional layer of oversight.⁵⁷ These committees should assess the potential benefits and risks of data-sharing initiatives, ensuring that any secondary use aligns with ethical standards and public interests.⁵⁸ Regular oversight can ensure that HIEs remain compliant with evolving legal and ethical requirements, thereby maintaining a responsible and patient-centered approach to data use.

RECOMMENDATIONS FOR IMPROVED LEGAL AND GOVERNANCE FRAMEWORKS

Enhanced privacy and consent standards

To address the limitations of current frameworks in protecting privacy and supporting informed consent in HIEs, significant improvements are necessary. Traditional consent models often fail to account for the dynamic and multifaceted nature of HIE data use, resulting in a lack of transparency and reduced autonomy for patients. The following strategies can help address these shortcomings:

1. Adopt dynamic consent models

Dynamic consent empowers patients to manage and update their preferences over time, providing greater control over how their health data is used. This model aligns with the evolving nature of healthcare data sharing and enhances patient autonomy.

○ Implementation steps:

- Design user-friendly platforms (e.g., mobile apps or patient portals) to allow patients to adjust their consent settings easily.⁵⁹
- Provide regular notifications or prompts to remind patients of their current consent preferences and offer opportunities to update them.⁶⁰
- Include features that enable patients to opt in or out of specific secondary data uses, such as research or public health initiatives.⁶¹

2. Integrate transparency-focused frameworks

Transparency-focused approaches, such as Proofs of Consent (PoC) and Consent-Based Access Control (CBAC), can significantly enhance trust in HIEs.

○ PoC:

- Maintain a verifiable record of all consent transactions to ensure that patients have a clear audit trail of how their data is accessed and used.¹⁴
- Develop systems that allow patients to view a detailed history of their consent decisions and data-sharing activities.⁶²

○ CBAC:

- Use cryptographic controls to confirm that access rights are verified before any data handling occurs.⁶³

- Implement role-based permissions to ensure that only authorized personnel can access specific data, minimizing the risk of unauthorized use.⁶²

3. Enhance patient education and engagement

Effective privacy and consent standards depend on patients' understanding of how their data is used and their ability to make informed decisions.⁶⁴

○ Educational tools:

- Provide clear, jargon-free explanations of consent options and their implications.
- Use interactive tutorials or videos within consent platforms to guide patients through their choices.

○ Engagement channels:

- Offer support through dedicated help lines or chatbots to answer patient questions about consent and privacy.
- Use patient feedback to refine consent processes and address common concerns.

By implementing these enhanced privacy and consent standards, HIEs can strengthen patient trust, ensure compliance with evolving legal frameworks, and support ethical data-sharing practices that align with the goals of modern healthcare. These measures provide patients with greater control and confidence in how their health information is managed, fostering a more transparent and patient-centered system.

Standardized liability regulations

The assignment of liability in HIEs is inherently complex due to the involvement of multiple entities, including healthcare providers, HIE operators, and third-party vendors. Each party has distinct privacy, security, and compliance responsibilities, which can blur accountability in the event of a data breach. To address these challenges, **standardized liability regulations** should be developed to establish clear, enforceable guidelines that define roles and responsibilities across all stakeholders.¹⁹

Key elements of standardized liability regulations

1. Clarity in accountability

Standardized regulations must delineate the specific obligations of each entity participating in an HIE.

- **Healthcare providers:** Ensure compliance with privacy and security measures, monitor data-sharing agreements, and respond promptly to breaches.⁶⁵

- **HIE operators:** Oversee data-sharing protocols, maintain infrastructure security, and coordinate breach responses.³³

- **Third-party vendors:** Implement robust cybersecurity practices and comply with contractual obligations related to data protection.⁶⁶

Clear guidelines on accountability reduce disputes over responsibility and streamline response efforts when breaches occur.

2. Uniform liability standards across jurisdictions

Fragmented liability standards across states or regions can create compliance challenges and legal uncertainties. National-level regulations, or even international harmonization, could promote consistency in handling breaches.⁶⁷

○ **Benefits:**

- Simplifies compliance for organizations operating across multiple jurisdictions.
- Reduces variability in breach responses, fostering patient confidence in the HIE system.

3. **Mandated insurance coverage for data breaches**

To mitigate the financial impact of breaches, regulations should require HIE participants to maintain adequate cyber liability insurance.⁶⁸

○ **Key features:**

- Coverage for breach response costs, including notification, remediation, and legal expenses.
- Financial protection for affected patients, such as compensation for identity theft or privacy violations.

This approach ensures that all entities are prepared to address potential breaches and their consequences.

4. **Ex post penalties for noncompliance**

Regulations should establish strict penalties for noncompliance with security and privacy standards.⁶⁹

○ **Examples of penalties:**

- Fines proportional to the extent of the breach and the degree of negligence involved.
- Suspension of participation in the HIE network for repeated violations.
- Mandated corrective actions, such as enhanced staff training or updated security protocols.

Penalties serve as both a deterrent and a mechanism to enforce adherence to liability standards.

5. **Standardized incident response protocols**

Liability regulations should include detailed requirements for breach notification and remediation.⁷⁰

○ **Requirements:**

- Timelines for notifying affected parties and regulatory bodies.
- Steps for investigating breaches and preventing recurrence.
- Coordination mechanisms for multi-entity breach responses.

Standardized protocols ensure a swift and transparent response, minimizing harm to patients and maintaining trust in HIE systems.

Benefits of standardized liability regulations

- **Legal certainty:** Eliminates ambiguities in assigning liability, reducing disputes and legal challenges.
- **Operational efficiency:** Streamlined breach response processes enhance coordination among HIE participants.
- **Patient trust:** Transparent liability frameworks reassure patients that their rights are protected and recourse is available in the event of a breach.

- **Improved risk management:** Encourages proactive adoption of best practices in cybersecurity and compliance.

By implementing standardized liability regulations, HIEs can create a cohesive legal and operational structure that safeguards patient data, promotes accountability, and supports the long-term viability of data-sharing initiatives. These measures provide a foundation for secure and trustworthy HIEs.

Adoption of data governance models

Ethical management of health data within HIEs requires robust governance models that prioritize transparency, accountability, and patient control. These models address legal, ethical, and operational challenges, fostering trust and enabling responsible data sharing.⁷¹

Key governance models

1. **Data trusts: Ethical oversight frameworks**

Data trusts act as neutral intermediaries, managing health data on behalf of patients.

- **Core functions:** Ensure that data use aligns with ethical standards and patient consent preferences, particularly for secondary uses like research or public health initiatives.

○ **Advantages:**

- Promotes accountability and ethical data use.
- Balances patient rights with innovation opportunities.
- Builds trust through clear oversight mechanisms.

- **Implementation needs:** Clear legal frameworks, transparent approval processes, and regular communication with patients.

2. **Participatory collective governance models**

Collective governance involves stakeholders—patients, providers, and policymakers—in decisions about data use.⁷²

○ **Key features:**

- Advisory boards or committees representing diverse interests.
- Public consultations to align governance with societal values.

○ **Benefits:**

- Enhances transparency and responsiveness.
- Encourages ethical sharing for research and public health initiatives.
- Builds public confidence in data-sharing practices.

- **Implementation needs:** Inclusive mechanisms like patient focus groups, with feedback loops to evaluate and adapt policies.

3. **Blockchain-enabled governance**

Blockchain provides a decentralized, secure system for managing data access and tracking usage.¹⁶

○ **Core benefits:**

- Immutable records and real-time tracking enhance transparency.

- Cryptographic controls strengthen security and access management.
- **Implementation considerations:**
 - Integrate with existing HIE infrastructure for seamless operation.
 - Address interoperability challenges to ensure broad compatibility.

Benefits of robust data governance

- **Trust building:** Transparent governance reassures patients about ethical and secure data use.
- **Operational efficiency:** Technology like blockchain reduces administrative burdens while maintaining data integrity.
- **Support for innovation:** Ethical frameworks encourage responsible data sharing for research and public health.

By adopting models like data trusts, collective governance, and blockchain-based systems, HIEs can enhance patient confidence, ensure ethical data use, and build a sustainable foundation for the future of healthcare data sharing. These models create a balanced approach to addressing privacy concerns while fostering innovation and improving public health outcomes.

CONCLUSION

Summary of key findings

This paper has highlighted the significant inadequacies within current legal frameworks governing HIEs, emphasizing the challenges they face in privacy protection, informed consent, and liability assignment. Traditional consent models, often based on one-time, static agreements, fail to capture the evolving nature of data use in HIEs, leaving patients under-informed about potential secondary uses of their data. Furthermore, privacy risks such as re-identification and data breaches raise serious ethical concerns, particularly in multi-entity HIE structures where liability is complex and often ambiguously defined. Current legal frameworks, fragmented by differing state, national, and international regulations, struggle to provide a cohesive system for data governance, risking compliance issues and diminished patient trust.

Implications for healthcare risk management

The findings in this paper underscore the importance of improved risk management practices in HIEs. By addressing the current gaps in legal protections, healthcare providers can better safeguard sensitive patient data and foster trust within HIEs. Enhanced privacy and consent models, as well as clear, standardized liability regulations, would not only protect patient rights but also create a more secure and transparent environment for data sharing. This has implications for healthcare policy, where stronger regulatory frameworks could help institutions preempt data breaches, reduce liability disputes, and

ultimately improve the operational stability of HIEs. Emphasizing ethical data governance also strengthens the relationship between patients and providers, fostering greater patient participation and, consequently, a more comprehensive healthcare data ecosystem.

Top 5 Strategies for managing legal risks in HIEs

- **Privacy risks:** Re-identification risks require advanced anonymization techniques (e.g., differential privacy).
- **Consent models:** Transition from static to dynamic consent to enhance patient autonomy and compliance.
- **Liability management:** Implement standardized agreements to delineate roles and responsibilities in HIEs.
- **Governance models:** Consider data trusts or blockchain to ensure accountability and transparency.
- **Cross-jurisdictional compliance:** Harmonize data protection standards to address fragmented regulations.

Future research directions

Future research should focus on empirical studies examining patient experiences with consent and privacy within HIEs. Understanding patient attitudes toward dynamic consent models and their perceived trust in various privacy safeguards can inform the development of more patient-centered data governance frameworks. Additionally, examining case studies on the effectiveness of different data governance models, such as data trusts or federated governance, would offer valuable insights into best practices for balancing patient rights with data utility. Finally, cross-jurisdictional studies are essential to explore how harmonized international standards could facilitate safer, compliant data sharing across borders, enhancing both the functionality and ethical integrity of HIEs on a global scale.

AUTHOR CONTRIBUTIONS

The author independently conceptualized and designed the study, gathered and analyzed the data, and wrote the manuscript. The author contributed significantly to the intellectual content of the paper and approved the final version for publication, taking full responsibility for all aspects of the article.

ACKNOWLEDGMENTS

This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

CONFLICT OF INTEREST STATEMENT

The author declares no financial or personal relationships that may have inappropriately influenced the work presented in this paper. The author has no affiliations or involvements in any organizations or entities with a direct financial or personal interest in the subject matter or materials discussed, including employment, consultancies, honoraria, stock ownership or options, expert testimony, grants or patents received or pending, royalties, or other potential sources of conflicts of interest.

Should any potential conflicts arise in the future, the author will promptly and publicly update this conflict-of-interest statement.

DATA AVAILABILITY STATEMENT

The data that support the findings of this study are available on request from the corresponding author. The data is not publicly available due to privacy or ethical restrictions.

ORCID

Tariq K. Alhasan LLB, LL.M.  <https://orcid.org/0000-0003-2957-334X>

REFERENCES

- Dixon BE. Introduction to health information exchange. In: Dixon BE, eds. *Health Information Exchange*. 2nd ed. Academic Press; 2023:3–20. doi:10.1016/B978-0-323-90802-3.00013-7
- Volpe S, ed. *Health Informatics: Multidisciplinary Approaches for Current and Future Professionals*. 1st ed. Productivity Press; 2022:45–50. doi:10.4324/9780429423109
- Alhasan TK. Integrating AI into arbitration: Balancing efficiency with fairness and legal compliance. *Conflict Resolution Quarterly*. 2025. doi:<https://doi.org/10.1002/crq.21470>
- Janakiraman R, Park E, Demirezen EM, Kumar S. The Effects of health information exchange access on healthcare quality and efficiency: an empirical investigation. *Manag Sci*. 2023;69(2):791–811. doi:10.1287/mnsc.2022.4378
- Busch-Casler J, Radic M. Trust and health information exchanges: qualitative analysis of the intent to share personal health information. *J Med Internet Res*. 2023;25:e4163. doi:10.2196/41635
- Mello MM, Adler-Milstein J, Ding KL, Savage L. Legal barriers to the growth of health information exchange—boulders or pebbles?. *Milbank Q*. 2018;96(1):110–143. doi:10.1111/1468-0009.12313
- AlZu'bi S, Elbes M, Mughaid A, et al. Diabetes monitoring system in smart health cities based on big data intelligence. *Future Internet*. 2023;15(2):85. doi:10.3390/fi15020085
- Mansour A, Al-Ahmed H, Deek A, et al. Developing green marketing strategies: a comprehensive analysis of consumer behaviour and business practices. *Int Rev Manag Mark*. 2024;14(6):206–212. doi:10.32479/irmm.17345
- Tarver WL, Jonnalagadda P, Rahurkar S. Evidence base for health information exchange. In: Dixon BE, ed. *Health Information Exchange*. 2nd ed. Academic Press; 2023:359–377. doi:10.1016/B978-0-323-90802-3.00019-8
- El Ouazzani Z, Cornetta G, et al. Privacy preserving in digital health: main issues, technologies, and solutions. In: Cornetta G, ed. *Social, Legal, and Ethical Implications of IoT, Cloud, and Edge Computing Technologies*. IGI Global; 2020:253–276. doi:10.4018/978-1-7998-3817-3.ch012
- Bincoletto G. EDPB guidelines 4/2019 on data protection by design and by default. *European Data Protection Law Review*. 2020;6:574.
- Doan X, Florea M, Carter SE. Legal-ethical challenges and technological solutions to e-health data consent in the EU. In: *HHAI 2023: Augmenting Human Intellect*. IOS Press; 2023:243–253. doi:10.3233/FAIA230088
- Bunting RF. The evolution of healthcare risk management. *J Healthc Risk Manag*. 2024;43:3–4. doi:10.1002/jhrm.21566
- Sittig DF, Ash JS, Wright A, et al. How can we partner with electronic health record vendors on the complex journey to safer health care?. *J Healthc Risk Manag*. 2020;40(2):34–43. <https://doi.org/10.1002/jhrm.21434>
- Abd-Alrazaq A, Alalwan AA, McMillan B, Bewick BM, Househ M, Al-Zyadat AT. Patients' adoption of electronic personal health records in England: secondary data analysis. *J Med Internet Res*. 2020;22(10):e17499. doi:10.2196/17499
- Pang Z, Yao Y, Li Q, Zhang X, Zhang J. Electronic health records sharing model based on blockchain with checkable state PBFT consensus algorithm. *IEEE Access*. 2022;10:87803–87815. doi:10.1109/ACCESS.2022.3186682
- Keshta I, Odeh A. Security and privacy of electronic health records: concerns and challenges. *Egypt Inform J*. 2021;22(2):177–183. doi:10.1016/j.eij.2020.07.003
- Mello MM, Adler-Milstein J, Ding KL, Savage L. Legal barriers to the growth of health information exchange—boulders or pebbles?. *Milbank Q*. 2018;96(1):110–143. doi:10.1111/1468-0009.12313
- Contreras JL, Nordfalk F. Liability (and) rules for health information. *Health Matrix*. 2019;29:179.
- Tertulino R, Antunes N, Morais H. Privacy in electronic health records: a systematic mapping study. *J Public Health*. 2024;32:435–454. doi:10.1007/s10389-022-01795-z
- Baek H, Cho M, Kim S, Hwang H, Song M, Yoo S. Analysis of length of hospital stay using electronic health records: a statistical and data mining approach. *PLoS One*. 2018;13(4):e0195901. doi:10.1371/journal.pone.0195901
- Rivera-Rios AC. Gaps and overlaps in US data health privacy oversight: preventing health tech, consumer, and patient health data from becoming the product. *J Health Care Finance*. 2020;47(1):1–28.
- de Carvalho Junior MA, Bandiera-Paiva P. Strengthen electronic health records system (EHR-S) access-control to cope with GDPR explicit consent. *J Med Syst*. 2020;44:172. doi:10.1007/s10916-020-01631-5
- Esmailzadeh P, Mirzaei T. Using electronic health records to mitigate workplace burnout among clinicians during the COVID-19 pandemic: field study in Iran. *JMIR Med Inform*. 2021;9(6):e28497. doi:10.2196/28497
- McKeown A, Mourby M, Harrison P, et al. Ethical issues in consent for the reuse of data in health data platforms. *Sci Eng Ethics*. 2021;27:9. doi:10.1007/s11948-021-00282-0
- Lee G, Kweon S, Bae S, Choi E. Overview of the EHRSQL 2024 shared task on reliable text-to-SQL modeling on electronic health records. *arXiv preprint arXiv:2405.06673*. 2024. doi:10.48550/arXiv.2405.06673
- Awotunde JB, Emmanuel AA, Busola FP, et al. Artificial intelligence and blockchain for robust healthcare delivery: from the perspective of security and confidentiality. In: *Artificial Intelligence and Blockchain Technology in Modern Telehealth Systems*. 1st ed. The Institution of Engineering and Technology; 2024:611–653. doi:10.1049/PBHE061E_ch21
- Holmgren AJ, Esdar M, Hüters J, Coutinho-Almeida J. Health information exchange: understanding the policy landscape and future of data interoperability. *Yearb Med Inform*. 2023;32(01):184–194.
- Alfawaer AM, Alhasan TK, Alfaoury AM. Ostensible agency in Jordanian civil law: An in-depth scrutiny of juridical frameworks and the imperative for legislative reformulation. *Relacoes Internacionais no Mundo Atual*. 2023;4(42):810–831. doi:<https://doi.org/10.21902/Revrima.v4i42.6566>
- Lee S, Kim Y, Cho S. Searchable blockchain-based healthcare information exchange system to enhance privacy preserving and data usability. *Sensors*. 2024;24(5):1582. doi:10.3390/s24051582
- Alhija MA, Al-Baik O, Hussein A, Abdeljaber H. Optimizing blockchain for healthcare IoT: a practical guide to navigating scalability, privacy, and efficiency trade-offs. *Indones J Electr Eng Comput Sci*. 2024;35(3):1773–1785. doi:10.11591/ijeecs.v35.i3.pp1773-1785
- Cascini F, Pantovic A, Al-Ajlouni YA, Puleo V, De Maio L, Ricciardi W. Health data sharing attitudes towards primary and secondary use of data: a systematic review. *eClinicalMedicine*. 2024;71:102551. doi:10.1016/j.eclinm.2024.102551
- Barth O, Anderson B, Jones K, et al. An innovative approach to using electronic health records through health information exchange to build a chronic disease registry in Michigan. *Prev Chronic Dis*. 2024;21:E41. doi:10.5888/pcd21.230413
- Rudin RS, Friedberg MW, Shekelle P, Shah N, Bates DW. Getting value from electronic health records: research needed to improve practice. *Ann Intern Med*. 2020;172(11)Supplement:S130–S136.
- Areiqat AY. Leveraging AI and FinTech: driving business innovation in the fourth industrial revolution. In: *Studies in Big Data*. Springer; 2025:158:703–709. doi:10.1007/978-3-031-70855-8_60

36. Miller AR. 5. Privacy of digital health information. In: Goldfarb A, Tucker CE, eds. *The Economics of Privacy*. University of Chicago Press; 2024:127–162. doi:10.7208/chicago/9780226834085-009
37. Farringer DR. Maybe if we turn it off and then turn it back on again? Exploring health care reform as a means to curb cyber attacks. *J Law Med Ethics*. 2019;47(S4):91-102. doi:10.1177/1073110519898046
38. Abramova EN, Starikova EV. Features of the civil liability associated with artificial intelligence technologies in healthcare services sector. In: Ivanov D, Panin A, Sukhanova I, eds. *Proceedings of ECSF 2021: Lecture Notes in Civil Engineering*, Vol 257. Springer; 2023. doi:10.1007/978-3-030-99877-6_3
39. Reuters. Law firm Thompson Coburn and healthcare client hit with data breach lawsuit. Reuters, 2024. Available at: <https://www.reuters.com/legal/litigation/law-firm-thompson-coburn-healthcare-client-hit-with-data-breach-lawsuit-2024-11-12/>
40. Chik WB, Sugumaran H. Legal governance of artificial intelligence in healthcare devices and services in Singapore. In: *Research Handbook on Health, AI and the Law*. Edward Elgar Publishing; 2024:373–391. doi:10.4337/9781802205657.00030
41. Yusuf MK, Danladi AJ, Shombot E, et al. The growing cybersecurity crisis in healthcare: a call to action. *Am J Innov Sci Eng*. 2024;3(3):55–68. doi:10.54536/ajise.v3i3.3576
42. Thangeda AR, Coleman A. Risk management framework to improve associated risk of information exchange between users of health information systems in resource-constrained hospitals. In: Gervasi O, et al, eds. *Computational Science and Its Applications—ICCSA 2020: Lecture Notes in Computer Science*, Vol 12254. Springer; 2020:123-134. doi:10.1007/978-3-030-58817-5_19
43. Alhasan TK, Al-Hawamdeh AM. Multi-tiered dispute resolution clauses in engineering contracts: a Jordanian legal perspective. *Confl Resolut Q*. 2024; 41(3): 299–317. <https://doi.org/10.1002/crq.21407>
44. Martin TR, Gasoyan H, Wierz DJ. Error by omission: a lack of integration across implementation and use in structuring health information technology contracts. *Health Informatics J*. 2020;26(3):2202–2212.
45. Tarawneh MA, Alhasan TK. Justice in the balance: the crucial role of disclosure in ensuring justice in Jordanian arbitration. *Confl Resolut Q*. 2024;42(1): 5–14. <https://doi.org/10.1002/crq.21427>
46. Choi SJ, Chen M, Tan X. Assessing the impact of health information exchange on hospital data breach risk. *Int J Med Inform*. 2023;177:105149. doi:10.1016/j.ijmedinf.2023.105149
47. Choi YB, Williams CE. A HIPAA security and privacy compliance audit and risk assessment mitigation approach. In: *Research Anthology on Securing Medical Systems and Records*. IGI Global; 2022:706–725. doi:10.4018/978-1-6684-6311-6.ch032
48. Toshev A, Petkova-Gueorguieva E, Mihaylova AA, et al. Digitalization of health care and aspects of implementing electronic prescriptions in Bulgaria. *Pharmacia*. 2024;71:1–6. doi:10.3897/pharmacia.71.e130302
49. Chen H, Grossman MR, Sen A, Tsao SF. *Establishing a FAIR, CARE, and Efficient Synthetic Health Data Sharing Ecosystem for Canada*. Department of Economics, University of Waterloo; 2024:15-20.
50. Khatatbeh M, Gharaibeh LF, Khabour OF, Abu-Farha RK, Alzoubi KH. Jordanian views regarding sharing of medical data for research: a cross-sectional study during COVID-19 pandemic. *PLoS One*. 2022;17(3):e0265695. doi:10.1371/journal.pone.0265695
51. Hijjawi GS, Eldahamsheh MM, Al-Quran AZF, et al. The mediating effect of digital supply chain management among the relationship between lean management and supply chain operations. *Int J Econ Bus Res*. 2023;26(2):146–162. doi:10.1504/IJEBR.2023.132642
52. Calloway SD. Consideration of standards and guidance related to informed consent. *J Healthc Risk Mgmt*. 2006;26(1): 39–45. <https://doi.org/10.1002/jhrm.5600260308>
53. Powell M. Consent, background justice and patterned privacy principles. *Polit Stud*. 2024;72(3):944–960. doi:10.1177/00323217231167074
54. Chevrier R, Foufi V, Gaudet-Blavignac C, Robert A, Lovis C. Use and understanding of anonymization and de-identification in the biomedical literature: scoping review. *J Med Internet Res*. 2019;21(5):e13484. doi:10.2196/13484
55. Aitken M, Cunningham-Burley S, Pagliari C. Moving from trust to trust-worthiness: experiences of public engagement in the Scottish Health Informatics Programme. *Sci Public Policy*. 2016;43(5):713–723. doi:10.1093/scipol/scv075
56. von Kalkreuth N, Kopka M, Appel J, Feufel MA. Unlocking the potential of the electronic health record — The influence of transparency features. In: *Proceedings of ECIS 2024*. AIS; 2024:1421. Available at: https://aisel.aisnet.org/ecis2024/track18_healthit/track18_healthit/5
57. Alhasan TK, Awaishah SM. The right of public employee to defend disciplinary penalty in Jordan. *Int J Public Law Policy*. 2024; 10(2): 190–203. <https://doi.org/10.1504/IJPLAP.2024.137783>
58. Scheibner J, Ienca M, Kechagia S, et al. Data protection and ethics requirements for multisite research with health data: a comparative examination of legislative governance frameworks and the role of data protection technologies. *J Law Biosci*. 2020;7(1):lsaa010. doi:10.1093/jlb/lsaa010
59. Wakenshaw SY, Maple C, Schraefel MC, Gomer R, Ghirardello K. Mechanisms for meaningful consent in Internet of Things. In: *Living in the Internet of Things: Cybersecurity of the IoT-2018*. IET; 2018:1–10. doi:10.1049/cp.2018.0014
60. Singh RG, Ruj S. Encoding of security properties for transparent consent data processing. In: *Proceedings of 2023 IEEE Gwangju Subsection Conference (GCON)*. IEEE; 2023:01–08. doi:10.1109/GCON58516.2023.10183463
61. Sondheim SE, Mattie A, Vigil J, McCulloch C, Feinn R. Correlation between hospital rating agencies' data: an analysis and recommendation. *J Healthc Risk Manag*. 2021;40:18-24. <https://doi.org/10.1002/jhrm.21413>
62. Narwal-Kasmani R, Stausmire JM, McCarthy KA, Buderer N, Gutek A, Ulrich CA. Assessment tool items for addressing physician-patient communication and reducing health care risk factors across multiple enterprise risk management domains. *J Healthc Risk Manag*. 2024;44:24–33. <https://doi.org/10.1002/jhrm.21581>
63. Awaishah SM. Digital justice in Jordan: the role of virtual arbitration sessions in modernizing the legal system. *Int J Cyber Criminol*. 2023;17(1):146–165. <https://doi.org/10.5281/zenodo.4766609>
64. Alhasan TK. From pathology to precision: Transforming multi-tiered dispute resolution clauses in international contracts. *Conflict Resolution Quarterly*. 2025. doi:<https://doi.org/10.1002/crq.21473>
65. Chen B, Floyd S, Jindal D, et al. What are the health consequences associated with differences in medical malpractice liability laws? An instrumental variable analysis of surgery effects on health outcomes for proximal humeral fracture across states with different liability rules. *BMC Health Serv Res*. 2022;22:590. doi:10.1186/s12913-022-07839-0
66. Wang Q, Jiang S, Ngai EWT, Huo B. Vendor selection in the wake of data breaches: a longitudinal study. *J Oper Manag*. 2024;70(4):568–599. <https://doi.org/10.1002/joom.1294>
67. Duffourc MN, Gerke S. The proposed EU directives for AI liability leave worrying gaps likely to impact medical AI. *NPJ Digit Med*. 2023;6:77. <https://doi.org/10.1038/s41746-023-00823-w>
68. Li Y, Mamou R. Modelling health-data breaches with application to cyber insurance. *Comput Secur*. 2023;124:102963. <https://doi.org/10.1016/j.cose.2022.102963>
69. Greco D. Commentary: COVID-19 compulsory vaccination for certain worker categories and the socio-economic consequences of noncompliance before Italy's Constitutional Court: a public health and human rights analysis. *J Glob Health Law*. 2024;1(1):106–118. <https://doi.org/10.4337/jghl.2024.01.06>
70. Bitzer M, Häckel B, Leuthe D, Ott J, Stahl B, Strobel J. Managing the inevitable—a maturity model to establish incident response management capabilities. *Comput Secur*. 2023;125:103050. <https://doi.org/10.1016/j.cose.2022.103050>
71. Lomotey RK, Kumi S, Ray M, Deters R. Synthetic data digital twins and data trusts control for privacy in health data sharing. In: *Proceedings of the 2024 ACM Workshop on Secure and Trustworthy Cyber-Physical Systems*. SaT-CPS '24. ACM; 2024:1–10. doi:10.1145/3643650.3658605
72. Bak MAR, Ploem MC, Tan HL, et al. Towards trust-based governance of health data research. *Med Health Care Philos*. 2023;26:185–200. doi:10.1007/s10109-022-10134-8

How to cite this article: Alhasan TK. Managing legal risks in health information exchanges: A comprehensive approach to privacy, consent, and liability. *J Healthc Risk Manag*. 2025;44:12–24.
<https://doi.org/10.1002/jhrm.70002>

AUTHOR BIOGRAPHY

Tariq K. Alhasan Lecturer Tariq K. Alhasan, Esq. LLB, LLM, is a lecturer in Commercial Law and Arbitration at Al-Ahliyya Amman University (Amman, Jordan). He holds an LLB and an LLM in Private Law from Al-Ahliyya Amman University, as well as an LLM in International Commercial Arbitration from Jerash University (Jerash, Jordan). A member of the Jordanian Bar Association, he is also a practicing lawyer and arbitrator. His research and practical experience focus on construction law, arbitration, commercial law, data privacy law, and AI.